



ServiceNow Hosted Instance API Security Incident — Threat Intelligence Report

Full Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-10
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Intelligence Report
Severity	High

TLP:CLEAR | Lost Boys Cyber | ServiceNow Hosted Instance API Security Incident — Threat Intelligence Report

Published: 2026-06-10 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings,

IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and

validated by a qualified security professional before operational use.

Table of Contents

- [1. Executive Summary](#)
- [2. Intelligence Requirement and Scope](#)
- [3. Source Review and Confidence](#)

- [4. Incident Overview](#)
- [5. Timeline](#)
- [6. Technical Analysis](#)
- [7. Threat Activity Assessment](#)
- [8. Infrastructure and Indicators](#)
- [9. Victimology and Targeting](#)
- [10. Detection Engineering](#)
- [11. Threat Hunting Guidance](#)
- [12. Risk Assessment](#)
- [13. Recommended Actions](#)
- [14. ATT&CK Mapping](#)
- [15. Bottom-Line Assessment](#)
- [16. References](#)

1. Executive Summary

Between 2-3 June 2026, attackers exploited a ServiceNow-hosted API access control failure to query data from a subset of customer instances before the vendor pushed a hosted fix on 5 June. Public reporting and multiple secondary sources consistently indicate the exposure was tied to an endpoint associated with `/api/now/related_list_edit/create` and a configuration state that allowed unauthenticated access. The most material enterprise risk is not only the direct exposure of tickets, employee records, workflow data, and security cases, but the secondary exposure of credentials, API tokens, integration secrets, and internal process knowledge commonly stored in ServiceNow records.

Expected impact is HIGH for directly affected tenants and MODERATE for the broader ServiceNow customer base. For affected organisations, likely consequences include regulatory notification pressure, third-party risk escalation, targeted follow-on intrusion using harvested secrets, and trust degradation around SaaS control boundaries. For customers not individually notified by ServiceNow, immediate platform compromise risk appears reduced after the 5 June hosted remediation, but log review, secret rotation for sensitive records, and validation of legacy/custom API exposure remain warranted.

2. Intelligence Requirement and Scope

This report assesses the June 2026 ServiceNow hosted-instance security incident, with emphasis on confirmed facts, assessed technical root cause, likely data at risk, detection implications, and expected business impact.

Available evidence points to unauthorised access against customer instances via a public-facing API control failure, not a broadly evidenced compromise of the ServiceNow corporate environment itself.

3. Source Review and Confidence

Source ID	Source	Assessment
SRC-001	ServiceNow support bulletin KB3067321 (quoted by secondary reporting)	High for quoted vendor statements; lower for absent technical specifics — Multiple independent outlets quote the same vendor language: hosted fix on 5 June 2026; unauthenticated user could gain greater access than intended; subset of customers observed with successful table queries; affected customers notified by case; CVE still under evaluation.
SRC-002	BleepingComputer reporting mirrored at note.f5.pm	High — Provides the clearest accessible summary of the vendor bulletin, affected scope, probable endpoint, and customer notification approach.
SRC-003	The CyberSec Guru analysis	Medium — Contains the strongest single-source technical narrative around the probable REST resource, requires_authentication flag, suspected IPs, and the 7 April internal problem-record claim. Useful but not fully vendor-confirmed.
SRC-004	Triskele Labs advisory	High — Adds pragmatic detection, scoping, and response guidance while clearly marking what is vendor-confirmed versus community-reported.
SRC-005	Anavem and other tertiary summaries	Medium — Useful to corroborate business-impact framing but not relied upon for unique technical claims.

4. Incident Overview

On 5 June 2026, ServiceNow applied a hosted security update to customer instances after identifying a security issue that could allow an unauthenticated user, in certain circumstances, to gain greater access to ServiceNow instances than intended.

According to the quoted vendor bulletin, ServiceNow detected anomalous activity and observed evidence of successful queries of instance tables for a subset of customers, then notified affected customers directly through support cases.

5. Timeline

Date	Event	Confidence
2026-04-07	Single-source claim that ServiceNow had internally documented the	Low-

Date	Event	Confidence
	issue in a problem record.	Medium
2026-06-02 to 2026-06-03	Observed anomalous activity and likely exploitation window across affected tenants.	High
2026-06-05	ServiceNow applies hosted fix restricting the affected endpoint to authenticated users.	High
2026-06-09	Customer notifications by support case and public reporting begin to surface.	High
2026-06-10	Defender-focused third-party analyses expand detection and response guidance.	High

6. Technical Analysis

6.1 Assessed Root Cause

Public reporting strongly suggests the incident involved a Scripted REST Resource associated with `/api/now/related_list_edit/create`. Multiple sources state the endpoint did not require authentication and that the 5 June update changed the configuration to authenticated-only access.

ServiceNow has not publicly confirmed the exact path or issued a public deep-dive advisory, so the endpoint-level explanation should be treated as a high-value working hypothesis rather than a fully public vendor-confirmed fact.

6.2 Affected Scope

- Customers on the Australia platform release.
- Customers on releases prior to Australia who made certain configuration changes.

6.3 Access Pattern and Logging Implications

- Several affected tenants reportedly observed a small cluster of hits against the probable endpoint.
- Unauthenticated activity may appear in transaction logs as Guest because no authenticated principal existed.
- Many customers may not be able to reconstruct full data access because REST message logging was not enabled beforehand.

6.4 Likely Data at Risk

- ITSM records including incidents, problems, change records, CMDB entries, and service requests.
- Security operations workflows, incident-response notes, vulnerability data, and case attachments.
- Employee-service data, internal documentation, workflow notes, and administrative attachments.
- Credentials, API tokens, screenshots, troubleshooting notes, and integration strings stored in records.

7. Threat Activity Assessment

No public evidence currently attributes the exploitation to a named actor. The activity is best understood as opportunistic exploitation of a high-value SaaS access-control failure.

- Operational architecture knowledge useful for later intrusion or social engineering.
- Embedded credentials or tokens stored in tickets and attachments.
- Security-process insight that can reveal monitoring blind spots.
- Help-desk and change-management detail that can be weaponised for trust-based attacks.

8. Infrastructure and Indicators

Type	Value	Confidence	Notes
Source IP	51.159.98.241	Medium	Most consistently cited suspicious IP tied to requests against the exposed endpoint.
Source IP	86.245.155.105	Low	Additional possible source IP mentioned in single-source technical reporting; treat as hunt lead rather than confirmed IOC.
URI Path	/api/now/related_list_edit/create	Medium	Community-reported vulnerable endpoint; vendor has not publicly confirmed the exact path.
User Context	Guest	Medium	Unauthenticated requests may appear in transaction logs as Guest due to missing user context.
Time Window	2026-06-02 through 2026-06-03 UTC	High	Observed anomalous activity window repeatedly cited across reporting.
Affected Scope	Australia release and some pre-Australia instances with specific	High	Vendor-quoted scope language.

Type	Value	Confidence	Notes
	configuration changes		

9. Victimology and Targeting

- Enterprises using ServiceNow as an operational system of record for ITSM, SecOps, HR, CMDB, and workflow automation.
- Healthcare, financial services, government, and MSP environments where ticket content may expose regulated or privileged information.
- Organisations with mature integrations that store secrets, connection strings, or troubleshooting artefacts inside records and attachments.

10. Detection Engineering

Priority	Signal	Why it matters
1	Requests to /api/now/related_list_edit/create during 2-3 June 2026	Highest-confidence hunt lead tied to public reporting.
2	Requests from 51.159.98.241 or 86.245.155.105	Useful infrastructure pivot, though not definitive alone.
3	Guest-context access to related-list edit operations	May identify unauthenticated activity hidden as non-user actions.
4	Spikes in table-query volume or unusual row-access patterns	Can reveal broader enumeration outside the IOC set.
5	Post-incident use of secrets stored in tickets or attachments	Detects follow-on exploitation rather than the initial access alone.

10.2 Example Microsoft Sentinel / KQL Hunt

kusto

```
let suspiciousIPs = dynamic(["51.159.98.241", "86.245.155.105"]);
let suspiciousPath = "/api/now/related_list_edit/create";
ServiceNowLogs
| where TimeGenerated between (datetime(2026-06-02) .. datetime(2026-06-06))
| where Url has suspiciousPath or RequestUri has suspiciousPath or RawData has suspiciousPath
```

```
| extend SourceIP = coalesce(ClientIP, SrcIPAddr, SourceIp, RemoteIP)
| extend UserContext = coalesce(User, UserName, Account,
tostring(parse_json(AdditionalFields).user))
| summarize Requests=count(), DistinctIPs=dcount(SourceIP), FirstSeen=min(TimeGenerated),
LastSeen=max(TimeGenerated) by Tenant=coalesce(Instance, TenantId, Hostname), SourceIP,
UserContext, tostring(HttpMethod), tostring(HttpStatus)
| order by Requests desc
```

10.3 Example Splunk Hunt

spl

```
index=servicenow (uri_path="/api/now/related_list_edit/create" OR
request_uri="/api/now/related_list_edit/create" OR _raw="/api/now/related_list_edit/create")
| eval source_ip=coalesce(src_ip, client_ip, remote_addr, ip)
| eval user_context=coalesce(user, user_name, account, principal, "unknown")
| search earliest="06/02/2026:00:00:00" latest="06/06/2026:23:59:59"
| stats count as requests min(_time) as first_seen max(_time) as last_seen values(method) as
methods values(status) as statuses by host source_ip user_context
| convert ctime(first_seen) ctime(last_seen)
| sort - requests
```

10.4 Example Sigma Analytic Logic

yaml

```
title: ServiceNow Related List Edit Endpoint Queried from Untrusted Source
id: 9a4694de-3e5f-42d4-a75a-182552620001
status: experimental
description: Detects requests to the community-reported ServiceNow endpoint associated with the
June 2026 hosted-instance security incident.
author: Lost Boys Cyber
logsource:
  category: webserver
  product: servicenow

detection:
  selection_path:
    cs-uri-stem|contains: '/api/now/related_list_edit/create'
  selection_ip:
    c-ip:
      - '51.159.98.241'
      - '86.245.155.105'
  condition: selection_path or (selection_path and selection_ip)
fields:
  - c-ip
  - cs-uri-stem
  - cs-method
  - sc-status
  - cs-username
falsepositives:
  - Legitimate internal testing of the same endpoint
level: high
```

11. Threat Hunting Guidance

- Pull all ServiceNow transaction, node, API gateway, reverse-proxy, and WAF logs for 1-6 June 2026.
- Hunt for the probable endpoint path, suspicious source IPs, and Guest-context related-list operations.
- Review records accessed in the relevant time window for secrets, attachments, screenshots, and architecture detail.
- Cross-check downstream authentication events in IdP, VPN, PAM, cloud, and developer platforms for exposed accounts or secrets.
- Monitor for phishing or impersonation activity themed around help-desk, incident response, or change-management processes.

12. Risk Assessment

Dimension	Assessment
Confidentiality	High for affected tenants because records may contain sensitive business data and credentials.
Integrity	Medium because public reporting most strongly supports successful query activity, but some community reporting suggests write attempts may also have occurred.
Availability	Low direct impact from the incident itself; main concern is downstream disruption if exposed secrets are abused.
Regulatory / Compliance	High for regulated organisations if personal, security, or support-case data was exposed.
Third-Party / Vendor Risk	High because the incident occurred inside a trusted SaaS workflow platform and challenges shared-responsibility assumptions.

13. Recommended Actions

13.1 Immediate (0-24 hours)

- Confirm whether your organisation received a ServiceNow support case tied to this incident.
- Preserve all relevant ServiceNow and perimeter logs from 1-6 June 2026.
- Identify records likely to contain secrets and begin risk-ranked secret rotation.
- Notify legal, privacy, and vendor-risk teams if suspicious access is confirmed.

13.2 Near-Term (1-7 days)

- Audit all Scripted REST Resources for authentication and ACL enforcement.
- Review attachments, tickets, and knowledge entries for plaintext credentials or sensitive troubleshooting artefacts.
- Validate WAF, IP restriction, and API-monitoring coverage around internet-reachable endpoints.
- Reassess vendor-assurance questions around notification timeliness and logging sufficiency.

13.3 Strategic (7-30 days)

- Reduce secret sprawl in ticketing and workflow systems.
- Create SaaS-focused incident-response playbooks for platforms that hold privileged operational data.
- Build detections for abnormal ServiceNow data access and post-ticket credential abuse.
- Threat-model workflow platforms as high-value information repositories, not just administrative tooling.

14. ATT&CK Mapping

Tactic	Technique	Confidence	Assessment
Reconnaissance	T1595 - Active Scanning	Medium	Attackers likely enumerated exposed ServiceNow tenants and tested the target API path across instances.
Initial Access	T1190 - Exploit Public-Facing Application	High	The exposed REST endpoint functioned as an internet-reachable application surface that could be queried without valid authentication.
Collection	T1213 - Data from Information Repositories	High	Vendor-confirmed successful table queries indicate collection from business-data repositories hosted inside customer instances.
Credential Access	T1552 - Unsecured Credentials	Medium	If tickets or attachments contained passwords, API keys, or troubleshooting secrets, exposed records could directly yield usable credentials.
Exfiltration	T1041 - Exfiltration Over C2 Channel	Low	Successful data querying is vendor-confirmed, but publicly available evidence does not yet prove broad downstream exfiltration volume or destination.

15. Bottom-Line Assessment

The strongest current evidence supports successful unauthorised data queries against a limited subset of customer instances rather than a universal platform-wide catastrophe. Even so, because ServiceNow often stores the exact operational detail attackers need for privilege escalation, social engineering, and secret abuse, any confirmed affected tenant should treat this incident as a possible precursor to broader compromise.

16. References

1. ServiceNow KB3067321, vendor support bulletin quoted in secondary reporting; customer portal access required.
2. BleepingComputer mirror: <https://note.f5.pm/go-422046.html>
3. The CyberSec Guru: <https://thecybersecguru.com/news/servicenow-api-vulnerability-breach/>
4. Triskele Labs: <https://www.triskelelabs.com/resources/servicenow-security-incident-unauthenticated-api-access-exposing-customer-data>
5. Anavem: <https://www.anavem.com/en/news/cybersecurity/servicenow-api-flaw-exposes-customer-data-in-security-breach>